

Honeywell Cyber Proactive Defence (CPD)

Internship Report:Threat Detection Rule Engine and Attack Chain Analysis

Chirag V Gaonkar

July 21, 2026

Contents

1	Introduction	2
1.1	Key Architectural Objectives	2
2	Conversion of Network Telemetry into a Knowledge Graph	2
2.1	Graph Entities: Nodes	2
2.2	Graph Relationships: Edges	3
2.3	Data Mapping Schema Summary	3
3	Core Threat Detection Rules & Theoretical Frameworks	4
3.1	Rule 1: Port Sweep & Network Reconnaissance	4
3.1.1	Ports	4
3.2	Rule 2: IT-OT Boundary Crossing	4
3.2.1	Theoretical Background	4
3.2.2	Detection Logic	5
3.3	Rule 3: Lateral Movement	5
3.3.1	Theoretical Background	5
3.3.2	Detection Logic	5
3.4	Rule 4: SMB / WinRM Relay & Pass-the-Hash (PtH)	5
3.4.1	Theoretical Background	5
3.4.2	Detection Indicators	5
3.5	Rule 5: Deception Decoy / Honeypot Interaction	6
3.5.1	Theoretical Background	6
3.5.2	Detection Logic	6
3.6	Rule 6: Privileged Account Running Multiple Concurrent Processes	6
3.6.1	Theoretical Background	6
4	Summary & Rule Mapping Matrix	7
5	Attack Chain Analysis	7
5.1	Graph-Based Attack Chain Workflow	7
5.2	Directed Propagation Graph Construction	7
6	Migration from Neo4j to OrientDB	7
6.1	Strategic Reasons & Benefits	8
6.2	Migration Summary & Mapping	8

1. Introduction

Modern enterprise environments are increasingly characterized by the convergence of Information Technology (IT) networks and Operational Technology (OT) infrastructures. While this integration drives operational efficiency, industrial automation, and real time monitoring, it significantly expands the organizational attack surface. Industrial control systems (ICS) and OT environments, traditionally air gapped are now exposed to sophisticated multi stage cyber threats.

The **Cyber Proactive Defence (CPD)** engine developed at Honeywell is designed as a specialized threat detection, correlation, and attack-chain analysis platform. Built upon the **MITRE ATT&CK for Enterprise and ICS** frameworks, CPD ingests telemetry across different network boundaries to identify anomalous behavior, track lateral threat propagation, and perform root cause reconstruction.

1.1 Key Architectural Objectives

- **Cross-Domain Visibility:** Correlating log events across IT endpoints, firewalls, Industrial Demilitarized Zones (IDMZ), and OT controllers (PLCs, RTUs, DCS).
- **Deterministic & Heuristic Rule Evaluation:** Executing multi stage rule logic to detect active reconnaissance, credential abuse, boundary traversal, and deception hits.
- **Attack Chain Analysis & Graph Modeling:** Mapping incident logs into directed acyclic graphs (DAGs) in a graph database (OrientDB) to trace attack propagation from root to impacted assets.

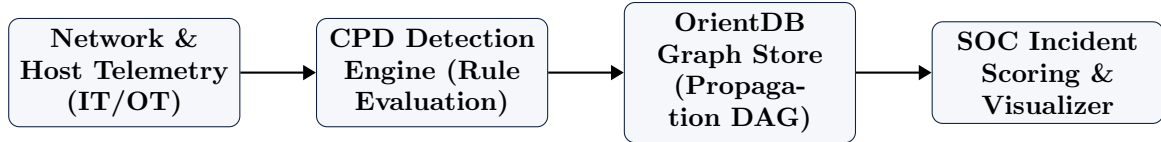


Figure 1: High-Level Telemetry Flow in the CPD Architecture.

2. Conversion of Network Telemetry into a Knowledge Graph

Converting raw network telemetry and system logs into a Knowledge Graph allows security analysts to represent complex relationships across heterogeneous assets. By mapping network components as nodes/vertices and interactions as directed relationships/edges, graph traversal algorithms can effectively trace attack paths and anomaly patterns. In graph databases like Neo4J and OrientDB these nodes serve as rich data containers. They have node id and other information in the form of key value pairs. The edges in graph databases store source and target nodes/ destinations and have other data in the form of key value pairs.

2.1 Graph Entities: Nodes

Nodes represent physical, virtual, or logical entities within the network ecosystem that generate events, manage data, or execute processes.

- **Asset & Infrastructure Nodes:**
 - **IPAddress:** IPv4 and IPv6 endpoints (both internal and external).

- **Host:** Workstations, servers, domain controllers, and cloud virtual machines.
- **Port / Service:** Open network ports (e.g., Port 22, Port 443) and running services (e.g., SSH, HTTPd).
- **Subnet:** CIDR blocks representing isolated or routed network segments.

- **Identity & Access Nodes:**

- **UserAccount:** Active Directory users, service accounts, and local administrative profiles.
- **Group / Role:** IAM roles, security groups, or organizational permission policies.

- **Execution & Data Nodes:**

- **Process:** Running system binaries identified by Process ID (PID) or cryptographic hash (e.g., SHA-256).
- **Domain / URL:** Fully Qualified Domain Names (FQDNs) resolved or contacted during outbound traffic.

2.2 Graph Relationships: Edges

Edges represent the connections, state permissions, or dynamic behavioral actions linking nodes together. Edges are typically categorized into static topological states and dynamic event-driven interactions.

- **Dynamic / Behavioral Edges (Event-Driven):**

- **:CONNECTED_TO:** Directed network traffic between two IP addresses or hosts (decorated with metadata such as byte count, packet size, and protocol).
- **:AUTHENTICATED_TO:** User authentication events to a specific host (annotated with success/failure status and timestamp).
- **:EXECUTED / :SPAWNED:** A user launching a process, or a parent process spawning a child process.

- **Static / Structural Edges (System State):**

- **:HAS_ADMIN_RIGHTS:** Administrative or privilege escalation paths from a user to an asset.
- **:MEMBER_OF:** Identity assignment to a group or role.

2.3 Data Mapping Schema Summary

Log Source	Source Node → Edge → Target Node	Type
NetFlow / VPC Logs	(IP: Src) $\xrightarrow{\text{:TRAFFIC_SENT}}$ (IP: Dst)	Behavioral
Auth Logs (Kerberos/SSH)	(User: Account) $\xrightarrow{\text{:AUTHENTICATED_TO}}$ (Host: Target)	Behavioral
EDR / Sysmon	(Process: Parent) $\xrightarrow{\text{:SPAWNED}}$ (Process: Child)	Behavioral
Active Directory / IAM	(User: Account) $\xrightarrow{\text{:HAS_ADMIN_RIGHTS}}$ (Host: Target)	Structural
Network Topology / Firewall	(Subnet: A) $\xrightarrow{\text{:CAN_REACH}}$ (Subnet: B)	Structural

Table 1: Mapping Telemetry Sources to Knowledge Graph Triples

3. Core Threat Detection Rules & Theoretical Frameworks

The CPD Detection Engine evaluates streaming network telemetry and event logs against 18 key attack indicators aligned with MITRE ATT&CK techniques. Some key ones are:

3.1 Rule 1: Port Sweep & Network Reconnaissance

MITRE ATT&CK ID: T1046 (Network Service Discovery)

3.1.1 Ports

A port is a logical communication endpoint used by a computer to distinguish between different network services running on the same IP address. An IP address identifies the destination machine, while the port number identifies the destination service on that machine. So, IP address is like the apartment name and port is like the house number.

Ports help the computer run multiple services at the same time. Firewalls use ports to decide what traffic to allow or block. HTTP:80, HTTPS:443, SSH:22

Before executing targeted exploits, adversaries conduct active reconnaissance to map active IP addresses, open ports, and running services across target subnets. A *port sweep* occurs when a single host systematically probes multiple destination IP addresses on a specific port or probes multiple ports on a single host within a compressed time window.

3.2 Rule 2: IT-OT Boundary Crossing

MITRE ATT&CK ID: T0886 (Remote Services in ICS) / Purdue Model Perimeter Violation

3.2.1 Theoretical Background

Industrial environments follow the **Purdue Model for Control Hierarchy** (Levels 0 through 5). Direct network communication from Level 3/4 (IT Enterprise) to Level 0–2 (OT Process Control and Controllers) without passing through an explicit Industrial DMZ (Level 3.5) proxy/jump host represents a severe architectural violation and potential compromise.

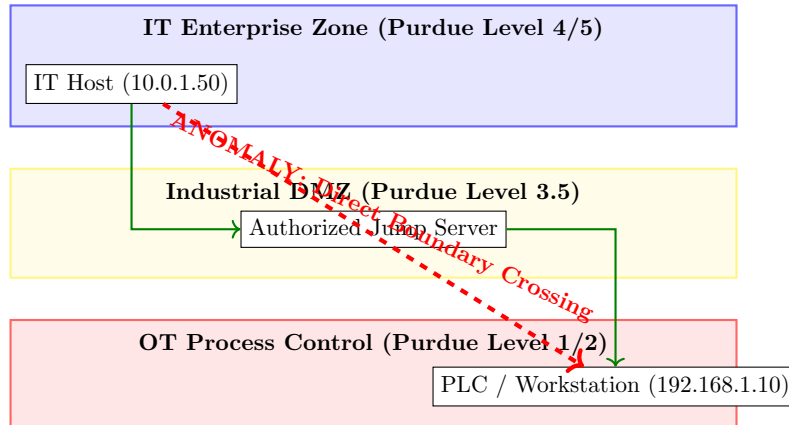


Figure 2: Visualizing Authorized IDMZ Traversal vs. Unauthorized IT-OT Boundary Crossing.

3.2.2 Detection Logic

The rule flags any TCP/UDP flow where $S_{ip} \in \text{Subnet}_{IT}$ and $D_{ip} \in \text{Subnet}_{OT}$.

3.3 Rule 3: Lateral Movement

MITRE ATT&CK ID: T1021 (Remote Services) / T1091 (Replication Through Removable Media)

3.3.1 Theoretical Background

Once inside an enterprise, adversaries pivot across hosts to extend access. In IT/OT networks, lateral movement frequently uses legitimate management tools (e.g., SSH, RDP, PsExec, WinRM) or proprietary industrial protocols (e.g., Modbus, EtherNet/IP, OPC UA) across non-adjacent subnet segments.

3.3.2 Detection Logic

The engine detects unexpected peer-to-peer administrative authentication patterns. It evaluates: 1. First-time connection pairs ($Host_A \rightarrow Host_B$) involving administrative ports (e.g., 22, 3389, 445, 5985). 2. Spanning-tree depth of authentication events originating from a single primary user credential within a short time window.

3.4 Rule 4: SMB / WinRM Relay & Pass-the-Hash (PtH)

MITRE ATT&CK ID: T1550.002 (Pass the Hash) / T1557.001 (LLMNR/NBT-NS Poisoning & SMB Relay)

3.4.1 Theoretical Background

SMB (Server Message Block) and WinRM (Windows Remote Management) are both Windows network protocols, but they serve very different purposes. **SMB** is primarily used for sharing files, folders, and printers over a network. **WinRM** is used for remotely managing and administering Windows computers by executing commands.

In Windows environments, authentication protocols often rely on NTLM hashes. NTLM stands for NT LAN Manager. It is a Microsoft authentication protocol. Pass-the-Hash (PtH) is an authentication attack in Windows environments where an attacker uses a stolen password hash directly to authenticate, without ever knowing or cracking the original password. If an attacker gains ADMIN/ SYSTEM privileges, then the attacker can do a memory dump (via Mimikatz or local registry) to get the hash and use it directly to authenticate to remote hosts via SMB or WinRM without ever decrypting the plaintext password.

In an ****SMB Relay**** attack, an adversary positions themselves in the middle (via LLMNR/NBT-NS poisoning), intercepts NTLM authentication responses from a victim client, and relays those credentials to a target server to execute a number of commands.

3.4.2 Detection Indicators

- **Event ID 4624 (Successful Logon):** Logon Type 3 (Network) utilizing NTLM authentication instead of Kerberos, where the source IP address does not match historical user-to-IP mapping.

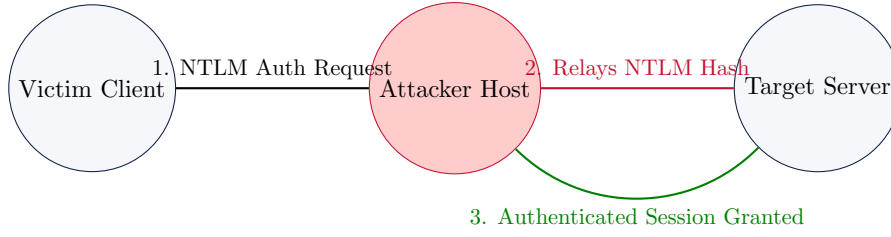


Figure 3: Operational Workflow of an NTLM / SMB Relay Attack.

- **WinRM Execution:** Sudden invocation of ‘wsmprovhos.exe’ spawned by non-standard parent processes with elevated local system privilege.
- Unusually high traffic between a host and a server.

—

3.5 Rule 5: Deception Decoy / Honeypot Interaction

MITRE ATT&CK ID: T1083 (File and Directory Discovery) / Threat Deception

3.5.1 Theoretical Background

Cyber Proactive Defence incorporates deception technology by deploying non-production ”honeypot” assets, decoy IP addresses, canary files, and fake credentials across both IT and OT segments. Because these assets serve no legitimate operational business purpose, any interaction with a decoy is treated as a high confidence early signal of an intrusion.

3.5.2 Detection Logic

$$\text{Alert}(S_{ip}) = \begin{cases} \text{CRITICAL}, & \text{if } D_{ip} \in \text{Decoy_IP_Pool} \\ \text{CRITICAL}, & \text{if Resource} \in \text{Canary_File_Registry} \end{cases} \quad (1)$$

When triggered, the rule instantly assigns the source host S_{ip} a maximum threat weight, causing the graph correlation engine to trace all historical inbound connections to S_{ip} to identify the entry point.

—

3.6 Rule 6: Privileged Account Running Multiple Concurrent Processes

MITRE ATT&CK ID: T1078 (Valid Accounts) / T1059 (Command and Scripting Interpreter)

3.6.1 Theoretical Background

Adversaries who compromise domain admin or service accounts frequently automate mass execution across multiple endpoints simultaneously using scripts (PowerShell, WMI, SSH loops). A sudden burst of concurrent administrative process executions across multiple distinct hosts under a single privileged account indicates automated post-exploitation (e.g., ransomware staging or environment-wide credential harvesting).

—

Rule Name	Primary Domain	MITRE ATT&CK Ref.	Telemetry Source
Port Sweep / Recon	IT / OT	T1046	Firewall / NetFlow
IT-OT Boundary Crossing	IDMZ / Purdue L3.5	T0886	Router ACL / IDS Logs
Lateral Movement	IT / OT Network	T1021	Auth Server / PCAP
SMB / WinRM Relay (PtH)	Windows Domain (IT)	T1550.002 / T1557	Windows Event Logs (4624)
Deception Decoy Hit	IT / OT Decoys	Threat Deception	Honeypot Daemon / Sinkhole
Privileged Account Anomaly	Enterprise AD	T1078	EDR / Active Directory

Table 2: CPD Engine Rule Mapping Matrix.

4. Summary & Rule Mapping Matrix

5. Attack Chain Analysis

An attack chain analysis maps out the step-by-step path an adversary takes through a system or network graph—from initial access to ultimate execution of malicious goals. Representing security telemetry as a graph allows security analysts to perform path-finding algorithms to detect and neutralize potential breach routes.

5.1 Graph-Based Attack Chain Workflow

1. **Initial Access Node:** Identifying vulnerable entry points (e.g., exposed services, phishing entry points, compromised credentials).
2. **Privilege Escalation & Lateral Movement:** Mapping relationships (:CAN_AUTHENTICATE_TO, :HAS_ADMIN_ON, :EXPLOITABLE_VIA) to calculate the shortest path to critical assets.

```
[Attacker Node] --(Compromises)--> [Workstation]
                --(Lateral Movement)--> [Server]
                --(Privilege Escalation)--> [Domain Admin]
```

Figure 4: Conceptual Graph Attack Path

5.2 Directed Propagation Graph Construction

To trace the spatial and temporal spread of an attack across the network, we construct a **Directed Propagation Graph** anchored to a specific incident ID. Given an initial security incident originating at a primary host node, a custom automated script identifies this compromised node as the root of the propagation tree. Because a high-level incident comprises an aggregated sequence of granular telemetry events, the script executes a **Breadth-First Search (BFS)** traversal starting from the root host to explore outward network connections iteratively. At each depth level of the traversal, neighboring host nodes are evaluated and ranked based on the number of events they triggered that were a part of the the root incidentr. This multi-layer BFS mechanism constructs a hierarchical, weighted attack path that isolates the exact lateral movement trajectory of the threat as it spreads from the initial point of compromise to secondary and tertiary targets.

6. Migration from Neo4j to OrientDB

Migrated from Neo4J to OrientDB to sync with other teams an meet long term goals.

6.1 Strategic Reasons & Benefits

- **Multi-Model Flexibility (Document + Graph):** While Neo4j is strictly a graph database, OrientDB combines document database capabilities with graph relationships. You can store complex payload attributes or full documents directly inside nodes without requiring excessive normalization or auxiliary key-value stores.
- **Performance & Scale Strategy:** OrientDB utilizes direct record-level pointers (RIDs) for relationships rather than heavy index lookups during traversal. Traversal speed remains constant regardless of the overall size of the database ($O(1)$ edge traversal), which is ideal for deep, multi-hop attack chain analyses.
- **Multi-Master Distributed Architecture:** OrientDB supports active-active multi-master replication natively across distributed clusters. This provides high availability and write scalability across multi-region environments, whereas Neo4j’s Causal Clustering relies on a single leader for write operations.
- **Licensing & Cost Efficiency:** OrientDB offers flexible open-source licensing (Apache 2.0) with enterprise features, providing a cost effective path for large scale enterprise graph deployments.

6.2 Migration Summary & Mapping

Feature / Concept	Neo4j	OrientDB Equivalent
Data Model	Pure Property Graph	Multi-Model (Document / Graph / Key-Value)
Node / Vertex	Node	Class extending V
Relationship / Edge	Relationship	Class extending E
Query Language	Cypher	Extended SQL / Match Syntax
Pointer Mechanics	Node-to-Node Pointers	Record IDs (#cluster:position)

Table 3: Neo4j to OrientDB Feature Mapping